3.3 Seguridad y datos personales

Propuesta de política para la Agencia; estado verificado del prototipo al 12/10/2026. Datos sintéticos del curso. No se afirma que haya controles de acceso o purga automáticos implementados.

1. Credenciales y secretos

PSEUDO_SALT vive en .env, excluido por .gitignore; .env.example es la plantilla de configuración. No incluir valores reales, archivos de entorno ni credenciales en Git. Las copias entregadas de dbt docs eliminan la sal del SQL compilado: los artefactos originales en dbt/target pueden contenerla y están ignorados. Rotar y custodiar la sal fuera del repositorio en producción; una rotación cambia las identidades y exige una migración controlada.

2. Seudonimización antes de Gold

El prototipo calcula usuario_sk = MD5(sal || persona_id) en Silver. Gold no incorpora tarjeta ni persona_id, pero sus hechos con usuario, estación y hora siguen siendo sensibles y reidentificables. MD5 con sal no garantiza anonimización; se propone HMAC-SHA-256 y una llave en un gestor de secretos para producción. Las exportaciones Tableau contienen agregados y no llaves individuales. La identidad AM permanece separada; no inventar vínculos.

3. Quién puede ver qué

Analista de movilidad: solo agregados Gold/Tableau, sin historial individual. Operadores: su propia información operativa y calidad. Auditor de fraude: detalle seudonimizado por caso, con autorización, plazo y registro de acceso. Custodio de identidad: Silver y correspondencia con tarjetas; acceso separado del analista. Ingeniería: ejecución y diagnóstico bajo mínimo privilegio. Responsable de privacidad: aprueba accesos excepcionales y retención. DuckDB local no implementa estos roles: deben imponerse mediante permisos del sistema y una plataforma con controles reales; aquí son reglas declaradas.

4. Retención y justificación

Propuesta: crudos/Bronze y cuarentena 90 días para conciliar y corregir; detalle individual Silver/Gold e identidad 180 días para investigar incidencias y comparar períodos; agregados sin identificación 24 meses para planificación; respaldos del detalle 30 días adicionales. Borrar o agregar al vencer el plazo; excepciones por investigación autorizada, documentadas y con vencimiento. El pipeline actual conserva datos sin purga automática. Los CSV individuales versionados de fase 1 contienen datos sintéticos; en un entorno real deben excluirse del repositorio y guardarse en almacenamiento restringido. La propuesta minimiza exposición sin impedir auditoría y planificación.